

PAYROLL

AUDIT PROGRAM #18-20-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
December 2025	Planning	Self-Service Report	Kohei Akama	Update OpenPages report exporting and other links and terms
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
December 2024	Planning	Reference Material, Self-Service Report and Fraud Template	Jessica Lin	Update links of Corporate Directives and added Self-Service Report
April 2023	Data Security and Privacy	IC003.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

PAYROLL AUDIT PROGRAM #18-20-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	9
PLANNING: Self-Service Report	10
PLANNING: Fraud Template.....	11
CONTROL ASSESSMENT QUESTIONS	12
Key Control Question: 1. Employee Validation/Compensation/Movement	12
Primary Test: Exceptions (EV001.P)	13
Primary Test: Employee Validation/Compensation/Movement (EV002.P).....	14
Primary Test: Separations (EV003.P)	15
Primary Test: High Salaries Verification (EV004.P)	16
Primary Test: Employee Deductions (EV005.P)	17
Key Control Question: 2. Internal Controls	18
Primary Test: Separation of Duties (IC001.P).....	19
Primary Test: Disbursement Controls (IC002.P)	20
Primary Test: Data Security and Privacy (IC003.P).....	21
Primary Test: Inputs, Processing, Outputs, and Distribution (IC004.P)	23
Key Control Question: 3. Accounting Controls	24
Primary Test: Ledger Controls and Reconciliations (AC001.P)	25
Primary Test: Payroll Accruals (AC002.P).....	26
Key Control Question: 4. Acquired Employees - Post Integration	27
Primary Test: Acquired Employees - Post Integration (AE001.P)	28
Key Control Question: 5. Business Continuity Planning.....	29
Secondary Test: Business Continuity Planning (BC001.S)	30
Key Control Question: 6. Vendor Management	33
Primary Test: Third-Party Provider or Supplier (VM001.P).....	34

PAYROLL

AUDIT PROGRAM #18-20-00

PROCESS AND OBJECTIVE

The payroll process is defined as programs, operations, and systems used to process, track, and control compensation payments and deductions in conjunction with personnel and finance organizations.

PAYROLL
AUDIT PROGRAM #18-20-00

PLANNING: Audit Program Risk Alignment

Payroll

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Vendor Management	High	Vendor Management	VM001.P
Employee Validation, Compensation, and Movement	Medium	Employee Validation/Compensation/Movement Acquired Employees - Post Integration	All AE001.P
Internal Controls	Medium	Internal Controls	All
Business Continuity Plan	Low	Business Continuity Planning	All

PAYROLL AUDIT PROGRAM #18-20-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Payroll Warehouse(s): Level of Access: Parameter(s): Reports:	- Balance sheet account summary showing large, aged variances between ledger and sub-ledger and large swing month-over-month - Duplicate payments - Verifying employee status against w3/People - Multiple Tax File Numbers or bank account numbers for one employee - Inconsistent payment dates compared to hire/termination/leave dates - Mismatches between payroll and employee master file (match by Talent ID – compare bank accounts, salary to pay rate, bonus, etc.)	- Inaccurate reconciliation between ledger and sub-ledger - Duplicate and/or inaccurate payments to employees - Inaccurate payments to employees	Poor design of and missing controls over the end-to-end payroll process could lead to invalid payments to employees, non-compliance with local laws and regulations, financial loss, and employee dissatisfaction.

PAYROLL AUDIT PROGRAM #18-20-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
	Reports for Payroll: • Overtime & premium payments for selected depts & or Talent IDs and depts. • Nonexempt Overtime & Premium payments for selected Talent IDs & or departments. • All Retention Payments within a specified timeframe. • Exempt Suppl. reptg more than 8 hours in a day (if applicable). • Exempt Suppl. with greater than 40 hours in a pay period (if applicable). • Duplicate social security numbers or government identifier numbers (>9) along with Talent ID, status, and employee info for active or separated employees during the audit period. • Duplicate social security numbers or government identifier numbers & payments made for active or separated employees during audit period. • Analysis identifying records on HR system not on Payroll app & Payroll app not on HR system (a) inside the audit period (b) outside the audit period (c) neither inside the audit period nor outside the audit period.		

PAYROLL AUDIT PROGRAM #18-20-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
	Determine from queries if any of the following exceptions exists: • mismatches between payroll and employee master file • payments to employees not on the employee master file • duplicate social security numbers or government identifier numbers or bank account numbers • duplicate names with different social security numbers or government identifier numbers or bank account numbers • bank account blank and net pay not equal to zero • payroll and personnel salary rates/bonus not equal or other compensation that is not according to approved rates, e.g., overtime, commission • payments to non-IBM beneficiaries (widows, orphans, incapacitated) • different Talent IDs with the same bank account	Inaccurate and inappropriate payments	Poor design of and missing controls over the end-to-end payroll process could lead to invalid payments to employees, non-compliance with local laws and regulations, financial loss, and employee dissatisfaction.
	For each exception perform testing using the suggested attributes of: • reason for exception documented • exception visible to and approved by management		

**PAYROLL
AUDIT PROGRAM #18-20-00**

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
	Concentrate on highest-risk elements, for example: • Inputs: initial or changes either not approved, not verified, or not timely • Processing: manual or exceptions either not reconciled, not approved or not verified • Outputs: inaccurate, errors not detected • Distribution: incorrect access to data and applications, separation of duties • Anything that is out of the ordinary monthly trending (beyond simple, unchanged, recurring salary payments)		

PAYROLL

AUDIT PROGRAM #18-20-00

PLANNING: Reference Material

Corporate Policies

130: IBM Data Privacy Policy defines, at a high-level, IBM's commitment to handling Personal Information and establishes the principles behind our practices

<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

Corporate Instructions

ITS 101: Information Technology Security establishes the requirements for the protection of IBM's worldwide information technology services and the information assets they contain

<https://w3.ibm.com/ibm/corporate-documents/its/its101>

- IT Security Standards <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html>

DG 101: Data Governance establishes the requirements for all IBM data in data governance and standards and worldwide record management

<https://w3.ibm.com/ibm/corporate-documents/cdo/dg101>

ET 127: Business Continuity Management is designed to help enable a business to prepare for, and survive, any disruption that threatens its ability to provide products and services and is intended to mitigate risk, to prevent the disruption of critical business operations due to the loss or reduced availability of people, facilities or IT services, and to minimize or eliminate the loss of valuable information

<https://w3.ibm.com/ibm/corporate-documents/et/et-127>

- Business Process Business Continuity BPBC127 Guideline <https://w3.ibm.com/w3publisher/global-bcm/bcm-ibm/bpbc127>

CIO 162: Financially Significant Applications and Other Enterprise Applications defines and identifies the Financially Significant (FinSig) and other widely used applications that are required to be used across the IBM Enterprise to optimize process effectiveness and cost

<https://w3.ibm.com/ibm/corporate-documents/cio/cio-162>

FIN 101: Control of Disbursements identifies the basic controls for disbursing IBM funds

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>

FIN 182 - Management Self Assessment of Control, Appendix C: Separation of Duties

<https://w3.ibm.com/w3publisher/financebc/ibm-framework/ci-fin-182-appendix-c>

HR 113: Protection of Employee Information sets forth the general practices for collecting, using, disclosing, storing, securing, accessing, transferring or otherwise processing employee information

<https://w3.ibm.com/ibm/corporate-documents/hr/hr-113>

LEG 116: Classification and Control of IBM Information specifies the controls for protecting information that IBM considers confidential. Note that generally, only Sensitive Personal Information should be classified 'IBM Confidential'

<https://w3.ibm.com/ibm/corporate-documents/leg/leg-116>

LEG 117: Internet Privacy notes the requirements for collecting Personal Information from visitors to IBM web pages

<https://w3.ibm.com/ibm/corporate-documents/leg/leg-117>

General Data Protection Regulation (GDPR)

GDPR Readiness Community

<https://w3.ibm.com/ibm/privacy/gdpr>

Data Privacy/Protection, Regulations, and Compliance: <https://w3.ibm.com/w3publisher/dprc>

PAYROLL AUDIT PROGRAM #18-20-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
• Management Self-Assessment of Controls (MSAC) • Risk Evaluations (RE's) • Proactive Business Control Reviews • (No key controls)	Login to OpenPages Risk, Controls and Assurance . Open User menu in top right, select FBC General User as profile, Open Primary menu in top left, select "Organization", and select "Processes" and then search payroll using search bar, and then select the applicable criteria to get the results.

PAYROLL

AUDIT PROGRAM #18-20-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Inadequate controls may result in invalid payments; litigation/arbitration; unauthorized deductions; and unapproved employee movements in or out of the company.	Validation of employee payments	Validate that payments (including benefits, additional compensation, deductions), employment periods, and additions/deletions for regular, non-regular employees are properly documented, approved, and processed timely and accurately.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Objective:

Are payments (including benefits, additional compensation, deductions, and separations), employment periods, and additions/deletions for regular, non-regular, and inactive employees valid, properly documented, approved, processed timely and accurately.

Risk/Exposure:

Inadequate controls may result in invalid payments; litigation/ arbitration; unauthorized deductions; unapproved employee movements in or out of the company.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Primary Test: Exceptions (EV001.P)

Objective:

Identify and investigate exceptions within the payroll process.

Approach:

1. Determine from queries if any of the following exceptions exists:
 - mismatches between payroll and employee master file
 - payments to employees not on the employee master file
 - duplicate social security numbers, government identifier numbers, or bank account numbers
 - duplicate names with different social security numbers, government identifier numbers, or bank account numbers
 - bank account blank and net pay not equal to zero
 - payroll and personnel salary rates/bonus not equal or other compensation that is not according to approved rates e.g., overtime, holiday, and shift rates.
 - if someone goes from non-exempt to exempt – eligibility
 - payments to non-IBM beneficiaries (widows, orphans, incapacitated, and students).
 - different Talent IDs with the same bank account
2. For each exception perform testing using the suggested attributes of:
 - reason for exception documented
 - exception visible to and approved by management
3. Concentrate on highest-risk elements, for example:
 - Inputs: initial or changes either not approved, not verified, or not timely
 - Processing: manual or exceptions either not reconciled, not approved or not verified
 - Outputs: inaccurate, errors not detected
 - Distribution: incorrect
 - Anything that is out of the ordinary (beyond simple, unchanged, recurring salary payments)

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Primary Test: Employee Validation/Compensation/Movement (EV002.P)

Objective:

For current regular and non-regular employees, confirm that payments were made to bona fide employees; payments are correctly calculated, properly reviewed and approved; and payments are in compliance with appropriate guidelines. Payments should include regular compensation, benefits, and additional compensation.

Approach:

1. Determine the universe of employee payments by type of employee (regular, temp, fixed-term contract, etc.) and by type of benefit (insurance, vacation, holidays, car allowance, etc.) and additional compensation (overtime, shift premium, mileage, etc.).
2. Randomly select new employees (six months or less service) and the longest-term employees, in proportion with the universe for employee types, benefits and additional compensation.
3. Validate the employees and associated payments using the following suggested attributes:
 - a. employee can be verified through confirmation of second line manager
 - b. start date and salary/pay rate match the personnel system and are accurate, and properly documented and approved.
 - c. last salary change was properly approved. If approvals are made electronically, verify that this is done by a personal user id (\$-id), that cannot be used by another person (secretary, deputy etc.).
 - d. hours paid are properly supported, reviewed and approved by management, and within established guidelines.
 - e. supporting documentation for benefits/additional compensation paid
 - f. additions and updates to employee file were independently reviewed
 - g. payslip accuracy
4. Test the reasonableness of overtime and shift premium payments. Were these properly approved? Did the overtime and shift premiums comply with local regulations, for example length of workday or week? Cross-check sampled payments to identify any made to ineligible employees, such as employees who are no longer working for IBM because they have separated or retired from IBM.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Primary Test: Separations (EV003.P)

Objective:

Determine whether effective controls exist to ensure that recording of regular and non-regular separations, leaves of absence, and other transfers out are accurate, timely, properly documented, and comply with established guidelines.

Approach:

1. From the universe of regular and non-regular employees who separated from IBM in the audit period, select a judgmental sample of separation activity.
2. Test supporting documentation for:
 - a. information provided by the Separations department and processed by Payroll
 - b. correct calculation of final payment
 - c. proper processing for settlement of all financial obligations to company
 - d. controls in place to prevent payment after separation.
 - i. test to validate that the control is working as intended to be assured that there was no payment after separation settlement date. (Look for employees who were separated, but continued to be paid, because separation paperwork might not have been promptly submitted and processed.)
 - e. settlement processed timely (should be able to determine the universe if you have the separation date and the settlement date)
3. For overpayments caused by delayed submission of separation checklists or delays completing the separation process:
 - a. Evaluate communications among HR's various global and country process owners and their organizations to determine whether steps such as reporting, trending, root cause analysis, and corrective action were taken to prevent delays in processing separations.
 - b. Note the types of payroll payments that were made after the employee stopped working for IBM: salary? overtime or shift premium? awards?
 - c. Which types of overpayments were explicitly approved by management after the employee left IBM?
 - d. What actions were taken to prevent overpayments?

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Primary Test: High Salaries Verification (EV004.P)

Objective:

Determine whether salaries and additional compensation for the top gross paid employees are valid, properly documented and approved.

Approach:

Select at least ten of the highest gross paid regular and non-regular employees. This test can be performed with employee validation / compensation / movement.

Test that:

1. employee is bona fide
2. compensation is valid
3. compensation is properly documented
4. compensation is properly approved

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Employee Validation/Compensation/Movement

Primary Test: Employee Deductions (EV005.P)

Objective:

Determine whether deductions for regular and non-regular employees are valid, accurate, processed timely, properly documented, and approved.

Approach:

1. Understand the various types of deductions for regular and non-regular employees and select a subset for review.

Examples of deductions are social security, income tax, IBM sponsored savings plans (deferred savings plan or equivalent), health programs, employee purchases.

2. The sample selections from Key Test EV002.P can be used to test for:
 - a. payslip accuracy
 - b. eligibility
 - c. payment accuracy
 - d. appropriate supporting documentation
 - e. management review and approval

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Objective:

Are internal controls effective in preventing or promptly identifying questionable payroll disbursements, and ensuring payroll related transactions are valid, approved and processed timely and accurately.

Risk/Exposure:

The lack of effective internal controls could result in failure to detect irregularities such as unauthorized payments, adjustments, or disbursements.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Primary Test: Separation of Duties (IC001.P)

Objective:

Ensure that a separation of duties assessment is performed and approved by the process owner or delegate annually, or more frequently as necessary. Validate that identified separation of duties conflicts are eliminated, mitigated, or accepted based on risk severity. Ensure that conflicting tasks which should be separated, but are not, have effective secondary controls.

Approach:

1. Was the end-to-end process reviewed at least annually and at the appropriate level? Were the results documented and approved by the process owner or delegate?
2. Were identified conflicts assessed for a determination? Was there supporting documentation to validate the assessment?
3. If secondary controls are needed, were they identified and would they mitigate the conflict effectively?
4. If financial processes are included in the end-to-end, were key controls for financial reporting (KCFRs) defined and implemented? Were they tested timely and properly with documented results?

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Primary Test: Disbursement Controls (IC002.P)

Objective:

Determine that there is adequate control over disbursement activities, including negotiable instruments, to ensure the prevention or prompt identification of misuse or misappropriation.

Approach:

1. Determine the number of disbursement options in use, and how each option is authorized and controlled. Test the effectiveness of the controls. Examples of disbursement options are:
 - a. checks (manual or system-generated, prenumbered or system-numbered, restricted payee (double bar), pre-signed, hand-signed, machine-signed or signature plate)
 - b. bank transfer
 - c. electronic transfer (physical file or transmitted)
2. Determine that the capability for processing bank account changes is restricted. (See Separation of Duties)
3. Determine that bank accounts are verified before disbursements are processed.
4. Determine if all names and Talent IDs on payroll file are reconciled to personnel file on periodic basis.
5. Review procedures for handling returned payments and ensure reasons are documented and accounting corrections are processed.
6. Review the procedures for handling negotiable instruments both before and after use. (See Reference Material for Negotiable Instruments)
7. Determine that disbursements to Payroll personnel are reviewed by a Payroll manager, and disbursements to a Payroll manager are independently reviewed using uneditable support documentation.

Take a representative sample from the various disbursement options, taking into account values disbursed and the level of risk. Sampling can be random, judgmental, stratified, or block based. Suggested attributes: timeliness of disbursement; disbursement amount matched to processing totals and supporting documentation; disbursement approved by an authorized approver.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Primary Test: Data Security and Privacy (IC003.P)

Objective:

Evaluate whether data, including personal information (PI) and sensitive personal information (SPI) is appropriately secured and protected.

Approach:

Evaluate physical security of areas where information is handled, stored, or discarded. Include office and work areas, file rooms, copier rooms, areas where checks are processed, areas where confidential material is discarded, etc. Look for unsecured laptops, exposed hard copy material, etc. If controlled access system means are used, how frequently are these monitored. Examples include badge access (granting, revalidating, revoking) or combination lock (changes to the combination).

Evaluate security of soft copy and electronic information. Check for password sharing, access to information processing equipment such as servers or storage devices, controls over access to applications (granting, periodic evaluation of business need, and revoking), and so forth.

Examine feeds from IBM to vendors (payroll processors, banks, investment firms, etc.), vendors to IBM, and from applications to the ledger. Test to see how management is assured that third parties are protecting data security and privacy.

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Primary Test: Data Security and Privacy (IC003.P)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Internal Controls

Primary Test: Inputs, Processing, Outputs, and Distribution (IC004.P)

Objective:

Are internal controls effective in preventing or promptly identifying questionable payroll disbursements, and ensuring payroll related transactions are valid, approved and processed timely and accurately.

Approach:

Concentrate on highest-risk elements, for example:

- Inputs: initial or changes either not approved, not verified, or not timely
 - Information from employees (such as personal information, withholdings, voluntary deductions, benefits choices, savings plan, employee stock purchase, bank account)
 - Information from managers (such as salary or band changes, awards if processed via payroll, transfers, changes in work location, leave of absence, separation, loans, or advances)
 - Information from others (such as tax, garnishment (legal action), overpayment recovery, new hire, special payments)
- Processing: manual or exceptions either not reconciled, not approved or not verified; errors not detected
- Outputs and Distribution: inaccurate, errors not detected
 - Direct deposit to bank account
 - Hard copy paychecks
 - Payment to governmental authorities, benefits administrators, savings plan administrators, etc.
 - Feeds to others, such as IBM general ledger, third party payroll processor, payroll, or other application
- How do the global process owner and the payroll processing organization monitor the effective, accurate, control of payments from inputs through processing to outputs and distribution?
 - Recurring payments such as salary
 - Special payments such as awards, overtime, shift premium, hiring bonus, incentives, salary changes
 - Items such as checks, including blanks, returned, voided, and signature plates

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Accounting Controls

Objective:

Are there effective accounting controls to ensure payments are appropriately authorized before release; transactions are recorded timely, accurately and in the appropriate general ledger accounts; and timely reconciliations are performed between the ledger and bank accounts and between payments and deductions within the payroll process.

Risk/Exposure:

Weak or inadequate controls to ensure accuracy within the payroll process could result in unauthorized payments/deductions; undetected omissions or errors; or fraudulent activities.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Accounting Controls

Primary Test: Ledger Controls and Reconciliations (AC001.P)

Objective:

To ensure that payments are recorded timely and accurately in the financial records.

Verify that effective controls are in place to ensure timely and accurate reconciliation between the payroll control totals, general ledger and associated bank accounts.

Approach:

1. Review feeder control reports for input from the payroll system to the ledger system for a period of one to three months, including a quarter-end. Suggested attributes: reconciliation performed timely and accurately; reconciliation properly approved; outstanding items aged and reported and cleared timely.
2. Account for manual entries.
3. Determine the ledger accounts related to payroll transactions and payroll bank accounts. Select a sample of accounts (including the primary payroll account, bank, control and clearing accounts, and one debit balance account) and check the reconciliations of those accounts for a period of one to three months, including a quarter-end. (Payroll control totals to ledger accounts to bank statement to CAATT (or alternative data)). Suggested attributes: reconciliation performed timely, accurately and properly approved; outstanding items aged, reported, and cleared timely; payroll account funded timely and accurately.
4. Select a sample of journal entries (minimum 10) for one quarter from those related to payroll activities (check payments, advances, etc.). Suggested attributes: entry made timely and accurately; entry properly approved; adequate supporting documentation. (This is an accounting task; however, this test can be performed as a secondary test, if necessary).

Note: If there has been a recent accounting audit, it may be possible to skip all or part of this test.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Accounting Controls

Primary Test: Payroll Accruals (AC002.P)

Objective:

Verify that effective controls are in place to ensure that payroll accruals are in accordance with generally accepted accounting principles and IBM practices.

Approach:

Select a sample of payroll accruals from the ledger. Focus on quarter-end, year-end activity, and high dollar transactions.

Review all accruals in terms of:

- Sufficient supporting documentation showing accruals are based on reasonable valuations
- Management approval
- Correct methodology
- Timeliness
- Appropriate reversal/usage in current year

Note: Special attention should be given to accruals where resulting payments will be made to government authorities.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Acquired Employees - Post Integration

Objective:

To ensure that employees that have been acquired by IBM in an acquisition and have completed the integration process, are aware of and in compliance with IBM corporate policies and processes regarding Payroll.

Risk/Exposure:

Employees bypassing the process could result in incorrect and inaccurate payments.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Acquired Employees - Post Integration

Primary Test: Acquired Employees - Post Integration (AE001.P)

Objective:

To ensure that employees that have been acquired by IBM in an acquisition and have completed the integration process, are aware of and in compliance with IBM corporate policies and processes regarding Payroll.

Approach:

For all cases, ask for information in the IDR on any acquisition that was fully integrated during the audit period in scope:

- If there has been an acquisition(s):
 - Request information on the timeline and integration status of the acquisition (note: in the US, there are going to be a number of acquisitions and they are going to be at various stages of integration)
 - Ask for a listing of the acquired employees including IBM Talent IDs and level (non-managers, managers, executives)
- To process payroll, which application and service provider are used? If different from the applications and service providers already used by IBM, how does management obtain assurance that the payroll is properly and promptly processed? At what point was the payroll for acquired employees (including managers and executives) to be migrated to applications and service providers already used by IBM? Did this change occur when required?
 - Look for timely processing of separations
 - If employee data was migrated to applications for processing, was all data properly migrated?
 - Was the information submitted by managers (including executives) new to IBM processed by payroll in a timely manner?
 - Look for unusual claims and payments. To the extent that any of these are associated with employees, managers, or executives new to IBM as a result of acquisitions, include in samples for testing.

NOTE: Unless notified by Legal of a different treatment due to compliance issues or special arrangements, acquired employees are to be included in the universe that is being audited. In addition, if the payroll process for the acquired entity is still in use, the audit team will need to understand that process and test it as it would the standard IBM process.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Business Continuity Planning

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Risk/Exposure:

Any material disruption of business operations due to natural or man-made disasters can lead to significant financial loss not only IBM but potentially also for IBM's customers. Many business processes have been centralized, and often operations are conducted in locations which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations in those centralized operations.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

Note: Business continuity risks become increasingly important in the environment where there are centers of excellence and multiple countries are supported by one center. This should therefore be an important test and considered primary in that environment. IT testing for disaster recovery is handled by the IT audit teams.

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Approach:

A guideline has been put in place for process owners providing guidance on business continuity planning (BCP). It should be noted by the audit team that this is a guideline rather than a specific instruction. However, it will act as a guide for you to understand whether key risks have adequately been considered for BCP and enable you to make an informed judgement regarding the risk mitigation in place. Different processes will have their own unique risk profiles regarding the probability and impact of an interruption to business operations. For example, the probability and impact of a business interruption for a process which has been centralized for multiple countries in a location with less-developed infrastructure is likely greater than that of a process supporting only a single country in location with robust infrastructure. As such, auditor judgment will be required to determine how important BCP is for a particular process, as well as to determine the reasonableness of any plans that have been designed by the process owners.

In the initial data request information ask for the process owner to confirm what plans have been implemented to ensure business continuity in the event of a natural or man-made disaster. Review that non-I/T process elements have been adequately considered in the BCP.

The following list of questions has been designed based on the BPBC127 Guideline for Business Process - Area Business Continuity Planning.

1. Has management assessed the risk to business continuity (BC) and identified the key business processes and activities that require formal business continuity planning based on impact to the business.
 - a. Identification and prioritization of business processes and activities in addition to prioritization done through by the Enterprise Process Owner (level 3 plans)
 - b. Understanding and documentation of the potential impact (financial, operational and reputation) to IBM from business disruptions from uncontrolled, non-specific events
 - c. Identification of the legal and regulatory requirements for the institution's business functions and processes
 - d. Review and approval from senior management
2. For critical business areas and processes, has the maximum acceptable outage (MAO) been established and considered in the BC plan?
 - a. Estimation of maximum allowable outage (MAO), based on the "acceptable level" of losses, associated with the institution's business functions and processes
 - b. Estimation of recovery time objectives (RTOs), recovery point objectives (RPOs), and Maximum Tolerable Downtime (MTD) of applications and supporting technology required for business operations
 - c. If applicable, recommended critical path recovery order
 - d. Reconciled with agreed IT recovery priorities (Business Criticality Values, RTO/MTD)

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

(Continued)

3. For business areas and processes where there is a business continuity risk, has the BC Plan been created, reviewed, and approved by management?
 - a. The organization shall establish documented procedures for responding to a disruptive incident and how it will continue or recover its activities within a predetermined timeframe.
 - b. Top management shall review the organization's BCMS, at planned intervals, to ensure its continuing suitability, adequacy, and effectiveness.
4. Does the Plan document the specific continuity and recovery actions for all four impact scenarios (workforce, workplace, IT, and regional) that will need to take place to mitigate risk to the business if the impact lasts longer than the documented business' maximum acceptable outage?
 - a. Flexible to respond to unanticipated threat scenarios and changing internal conditions.
 - b. Focused on the impact of various threats that could potentially disrupt operations rather than on specific events.
 - c. Effective in minimizing service disruptions and financial loss through the implementation of mitigation strategies.
5. Does the BC plan clearly identify dependencies such as site resources, IT, suppliers, process interdependencies, partners, non-IT services and been reviewed and synchronized with the appropriate crisis management team?
 - a. An effective BCP coordinates across its many components, identifies potential process or system dependencies, and mitigates the risks from interdependencies.
6. Is there an established, management-endorsed business continuity team to oversee the maintenance, invocation, and execution of the BC plan?
 - a. Defined roles and responsibilities for people and teams having authority throughout an incident.
 - b. Additional teams as necessary to facilitate recovery execution per the chosen strategy.
7. Are personnel aware and educated on the plan, strategy, and roles?
 - a. Business continuity training should be an integral part of the BCM.
 - b. Comprehensive training program should be developed for all employees, conducted at least annually, and kept up to date to ensure that everyone understands their current role in the overall recovery process.
 - c. An audit trail should be maintained to document management's training efforts.
8. Is there a regularly executed process for validating the Plan through tests including key elements such as people, technology (data, systems, applications, and telecommunications), and locations that house staff and technology to ensure fit for purpose and alignment with current risks?
 - a. Tests should be based on appropriate scenarios that are well planned with clearly defined aims and objectives that promote continual improvement.
 - b. Produce formalized post-exercise reports that contain outcomes, recommendations, and actions to implement improvements and are reviewed with management.
 - c. Tests are conducted at planned intervals and when there are significant changes within the organization or to the environment in which it operates.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

(Continued)

9. FOR COMMERCIAL CONTRACTS: Where IBM has customer contracts including business continuity planning, have BC plans been implemented in accordance with contractual obligations?

FOR CUSTOMERS WITH REGULATORY REQUIREMENTS: Does the plan accommodate and account for the any unique rigor or accommodations for the regulatory body.

- a. Adherence with contractual obligations contained in the IBM Responsibilities section of the Schedule or similar agreement. Including communication, recovery parameters, specialized technical designs.
- b. Special considerations to meet unique regulatory requirements (HIPAA – US Healthcare has unique wording on backup, protection, and availability of data).

Note: Refer to BPBC127 Guideline for Business Process - Area Business Continuity Planning in the reference section of this audit program, in support of your review.

PAYROLL AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Vendor Management

Objective:

Are the responsibilities of the third-party provider or supplier versus the main location defined and documented.

Are controls and documentation adequate to process payments/ deductions accurately and timely, protect PI and SPI, and deter/detect fraudulent activities?

Risk/Exposure:

Inadequately defined responsibilities and controls could result in inaccurate payments/deductions and provide the opportunity for fraudulent activities.

PAYROLL

AUDIT PROGRAM #18-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Vendor Management

Primary Test: Third-Party Provider or Supplier (VM001.P)

Objective:

Verify that procedures for processing payroll and personnel transactions from the third-party provider or supplier are clearly defined; effective in preventing and identifying misuse or misappropriation; ensure accurate and timely processing; and data security.

Approach:

1. Review the process contracts for payroll transactions handled from the third-party provider or supplier.
2. Review the contract requirements for key data privacy with third-party provider.
3. From prior quarter end perform applicable tests selected from lists referenced with each Key Control Question.
4. Review transmission of information, evaluating data security and privacy.

Note: Test may require modification to meet differences between the Main and third-party provider or supplier.

In addition, test any control points documented in Contract not covered in the established tests.